PASO 9 · TPRM, PRIVACIDAD E INTELIGENCIA ARTIFICIAL

Operación Trazabilidad · Documento actualizado con el expediente disponible · 09/11/2026

Limitación general: las conclusiones se mantienen como no concluyentes cuando no hay contrato completo, informe SOC 2 íntegro, registros originales o pruebas ejecutadas. No se atribuyen obligaciones al proveedor sin validar el contrato.

Ficha TPRM

Hoja 1 de 5 · Contenido y observaciones del expediente

FICHA DE EVALUACIÓN TPRM								
Proveedor / servicio	**Servicio prestado**	**Criterio de revisión**	**Información / evidencia revisada**	**Resultado**	**Riesgo / observación**	**Fuente / referencia**	**Riesgo relacionado**	**Prueba diseñada**
Proveedor Cloud (nombre no especificado)	Servicios de nube y respaldos	Existencia y revisión del contrato con el proveedor	El expediente inicial identifica la evidencia E-09 como contrato del tercero. Se indica un SLA del 99.9% con exclusiones sujetas a interpretacion. No se proporciona el contrato integro en el resumen inicial	No concluyente	Falta verificar las cláusulas contractuales y las obligaciones específicas del proveedor.	E-09 – Contrato del tercero.	R-06	T-06 (diseñada; no ejecutada)
Proveedor Cloud (nombre no especificado)	Servicios de nube y respaldos	Acuerdos de nivel de servicio (SLA)	El expediente inicial indica que el contrato del tercero establece un SLA de disponibilidad del 99.9 %. También señala que existen exclusiones sujetas a interpretación. No se dispone del detalle completo de las cláusulas para verificar su alcance.	No concluyente	Las exclusiones del SLA podrían generar diferencias en la interpretación de las obligaciones de disponibilidad.	E-09 – Contrato del tercero (SLA 99.9 % y exclusiones).	R-06	T-06 (diseñada; no ejecutada)
Proveedor Cloud (nombre no especificado)	Servicios de nube y respaldos	Cumplimiento de controles de seguridad de la información	El expediente inicial señala que existen subcontratistas del proveedor cloud que no fueron incluidos en la evaluación TPRM. Además, el informe SOC 2 presentado no cubre todos los servicios contratados. No se proporciona documentación suficiente para verificar la totalidad de los controles de seguridad aplicados.	No concluyente	La cobertura incompleta de los controles de seguridad y la falta de evaluación de subcontratistas limitan la revisión integral del proveedor.	Alerta 05 – Subcontratistas no incluidos en la evaluación TPRM. Declaración del Comité de Auditoría sobre cobertura SOC 2.	R-06	T-06 (diseñada; no ejecutada)
Proveedor Cloud (nombre no especificado)	Servicios de nube y respaldos	Certificaciones o informes de auditoría, como SOC 2	El expediente inicial indica que el tercero presentó un informe SOC 2; sin embargo, este no cubre todos los servicios contratados por RedNova. Se requiere revisar el alcance del informe para identificar los servicios incluidos y aquellos que quedan fuera de su cobertura.	No concluyente	El expediente indica que existe un informe SOC 2, pero su alcance no cubre todos los servicios contratados. El informe íntegro no está disponible para verificar independientemente la cobertura.	Declaración del Comité de Auditoría sobre alcance SOC 2; documento íntegro pendiente.	R-06	T-06 (diseñada; no ejecutada)
Proveedor Cloud (nombre no especificado)	Servicios de nube y respaldos	Control de accesos del proveedor a los sistemas de RedNova	El expediente inicial señala que existen cuentas administrativas compartidas entre personal interno y externo, y que MFA no cubre todos los accesos privilegiados. Además, el 12 de octubre de 2026 un proveedor solicitó la renovación de acceso privilegiado a una API, cuya autorización estaba pendiente. El 14 de octubre se registró un inicio de sesión remoto de la cuenta ext_ops_04 sin MFA. Se requiere verificar la autorización, titularidad y actividad de dicha cuenta.	No concluyente	Se reportan cuentas administrativas compartidas y cobertura MFA incompleta. La sesión ext_ops_04 sin MFA está descrita en la cronología, pero no se ha confirmado documentalmente su vínculo con este proveedor.	Alertas 02 y 03; E-01 y E-02; cronología del incidente. Logs originales pendientes.	R-03	T-03 (diseñada; no ejecutada)

FICHA DE EVALUACIÓN TPRM								
Proveedor Cloud (nombre no especificado)	Servicios de nube y respaldos	Gestión de subcontratistas y terceros involucrados	El expediente inicial señala que el proveedor de nube utiliza subcontratistas que no fueron incluidos en la evaluación TPRM. No se proporciona información sobre la identidad de estos subcontratistas, los servicios que prestan ni los accesos que poseen. Se requiere revisar su participación y las responsabilidades correspondientes.	No concluyente	La falta de evaluación de los subcontratistas puede dejar riesgos de terceros sin identificar ni controlar.	Alerta 05 – Subcontratistas del proveedor cloud no incluidos en la evaluación TPRM.	R-06	T-06 (diseñada; no ejecutada)
Proveedor Cloud (nombre no especificado)	Servicios de nube y respaldos	Realización y protección de copias de seguridad	El expediente inicial identifica en E-08 que los respaldos se realizan de forma automática, pero las pruebas de restauración no se ejecutan periódicamente. Además, la restauración documentada más reciente ocurrió varios meses antes del incidente. No se proporciona información suficiente para confirmar la protección e integridad de todas las copias de seguridad ni su responsabilidad específica por parte del proveedor.	No concluyente	E-08 describe respaldos automáticos y ausencia de pruebas periódicas recientes de restauración. No se dispone de soporte suficiente para atribuir al proveedor la responsabilidad contractual específica.	E-08 y alerta 07; registros originales de respaldo/restauración pendientes.	R-08	T-08 (diseñada; no ejecutada)
Proveedor Cloud (nombre no especificado)	Servicios de nube y respaldos	Capacidad de recuperación y continuidad del servicio (BIA)	El expediente inicial señala que el análisis de impacto al negocio (BIA) y los planes de continuidad se encuentran desactualizados. Durante el incidente del 14 de octubre de 2026, el CRM dejó de estar disponible a las 03:42, retornó en modo de solo consulta a las 08:57 y restableció las operaciones de escritura a las 09:37. Se requiere verificar los objetivos RTO y RPO, los procedimientos de recuperación y la participación del proveedor cloud.	No concluyente	El expediente indica que BIA y planes de continuidad están desactualizados. Los intervalos observados del CRM fueron 5 h 15 min hasta solo lectura y 5 h 55 min hasta escritura; no son por sí mismos RTO/RPO aprobados.	Alerta 11 y cronología del incidente del 14/10/2026.	R-08	T-08 (diseñada; no ejecutada)
Proveedor Cloud (nombre no especificado)	Servicios de nube y respaldos	Procedimiento de notificación y gestión de incidentes	El expediente inicial identifica en E-07 una alerta crítica de seguridad sin cierre documentado. No se proporciona información suficiente para verificar el procedimiento de notificación de incidentes del proveedor, los plazos de comunicación a RedNova ni las responsabilidades de cada parte durante la atención del incidente.	No concluyente	Una alerta crítica sin cierre documentado puede dificultar el seguimiento y la verificación de incidentes de seguridad.	E-07 – Alertas de seguridad. Cronología del incidente (14 de octubre de 2026, 03:18).	R-06	T-06 (diseñada; no ejecutada)
Proveedor Cloud (nombre no especificado)	Servicios de nube y respaldos	Ubicación, almacenamiento y transferencia de información	El expediente inicial indica que RedNova utiliza servicios de nube y servidores híbridos. También señala que la información personal de los clientes no cuenta con una clasificación formal documentada. Durante el incidente se identificó una transferencia aproximada de 1.6 GB hacia un destino externo no clasificado, sin que se haya determinado el contenido transferido. No se especifica la ubicación geográfica de almacenamiento ni las condiciones de transferencia de datos establecidas con el proveedor.	No concluyente	Se reportan aproximadamente 1.6 GB hacia un destino externo no clasificado; el contenido y destino final no están determinados. Este dato no demuestra por sí solo exfiltración de datos personales.	E-04 y cronología del incidente (14/10/2026, 02:35); logs originales pendientes.	R-07	T-07 (diseñada; no ejecutada)
Proveedor Cloud (nombre no especificado)	Servicios de nube y respaldos	Protección y confidencialidad de los datos	El expediente inicial señala que la información personal de los clientes no cuenta con clasificación formal documentada. Se requiere verificar las medidas de protección y confidencialidad aplicadas a los datos almacenados o procesados por el proveedor cloud, así como las responsabilidades establecidas entre RedNova y el tercero.	No concluyente	La falta de clasificación formal de los datos personales dificulta determinar los niveles de protección y acceso necesarios.	Alerta 06 – Información personal de clientes sin clasificación formal documentada.	R-07	T-07 (diseñada; no ejecutada)

FICHA DE EVALUACIÓN TPRM								
Proveedor Cloud (nombre no especificado)	Servicios de nube y respaldos	Procedimiento de finalización del servicio y eliminación de datos	El expediente inicial no proporciona información específica sobre el procedimiento de finalización del servicio del proveedor cloud, la devolución de información a RedNova ni la eliminación segura de los datos almacenados. Se requiere revisar el contrato y sus anexos para verificar las condiciones de retención, devolución y eliminación de información al finalizar la relación contractual.	No concluyente	No se recibió el contrato íntegro ni sus anexos para confirmar retención, devolución, eliminación segura y plazos posteriores a la terminación.	E-09 – referencia al contrato del tercero; contrato y anexos completos pendientes.	R-06	T-06 (diseñada; no ejecutada)

Responsabilidad Compartida

Hoja 2 de 5 · Contenido y observaciones del expediente

TABLA DE RESPONSABILIDAD COMPARTIDA					
Componente / actividad	**Responsabilidad de RedNova**	**Responsabilidad del proveedor**	**Evidencia contractual / técnica**	**Observaciones**	**Riesgo / prueba**
Infraestructua Cloud	Definir los servicios requeridos y configurar los recursso contratados	Administrar la infraestructura clouad segun el servi cio contratado	E-09 – Contrato del tercero.	Responsabilidades específicas pendientes de validar contractualmente La asignación definitiva debe confirmarse con el contrato y el modelo de servicio.	R-06 / T-06 (prueba diseñada; no ejecutada)
Adminsitracion de accesos	Autorizar usuarios, asignar permisos y revisar accesos	Administrar los accesos de su personal a los recursso bajo su responsabilidad	E-09 – Contrato y cláusulas de acceso.	Se requiere verificar los permisos y responsabilidades de administración La asignación definitiva debe confirmarse con el contrato y el modelo de servicio.	R-03 / T-03 (prueba diseñada; no ejecutada)
Autenticacion y MFA	Establecer y exigir MFA para los accesos correspondientes	Aplicar MFA a sus propios accesos administrativos, segun el contrato	E-01 y E-02 – Usuarios, privilegios y acceso VPN.	Se requiere confirmar la cobertura de MFA para los accesos del proveedor La asignación definitiva debe confirmarse con el contrato y el modelo de servicio.	R-03 / T-03 (prueba diseñada; no ejecutada)
proteccion de datos	Clasificar los datos y definir los requisitos de proteccion	Proteger los datos alojados o procesados segun las obligaciones contratadas	Documentación de protección de datos y alcance SOC 2.	Se requiere verificar las medidas de protección aplicadas La asignación definitiva debe confirmarse con el contrato y el modelo de servicio.	R-07 / T-07 (prueba diseñada; no ejecutada)
Seguridad de la infraestructura	Configurar y proteger los componentes que adminsitra RedNova	Proteger los componenetes de infraestructura que adminsitra	Informe SOC 2 y documentación técnica del proveedor.	El informe SOC 2 no cubre todos los servicios contratados La asignación definitiva debe confirmarse con el contrato y el modelo de servicio.	R-06 / T-06 (prueba diseñada; no ejecutada)
Subcontratistas	Evaluar y aprobar los riesgos asociados a terceros	Informar sobre subcontratistas y controlar sus servicios	Documentación de subcontratistas y evaluación TPRM.	Existen subcontratistas no incluidos en la evaluación TPRM inicial La asignación definitiva debe confirmarse con el contrato y el modelo de servicio.	R-06 / T-06 (prueba diseñada; no ejecutada)
Copias de Seguridad	definir las necesidades de respaldo y verificar las restauraciones	Ejecutar los respaldos que esten incluidos en el servicio contratado	E-08 – Respaldos.	Existen respaldos automáticos, pero no se prueban periódicamente las restauraciones La asignación definitiva debe confirmarse con el contrato y el modelo de servicio.	R-08 / T-08 (prueba diseñada; no ejecutada)
Continuidad y Recuperacion	Definir prioridades, RTO y RPO, y coordinar la recuperacion del negocio	Apoyar la recuperacion de los servicios bajo su responsabilidad	BIA, RTO, RPO y planes de continuidad.	Los planes BIA y de continuidad están desactualizados La asignación definitiva debe confirmarse con el contrato y el modelo de servicio.	R-08 / T-08 (prueba diseñada; no ejecutada)
Monitoreo y Registros	Supervisar sus sistemas y conservar los registros que genera	Generar y conservar los registros e los servicios que adminsitra	E-07 – Alertas de seguridad y registros de monitoreo.	Existe una alerta crítica sin cierre documentado La asignación definitiva debe confirmarse con el contrato y el modelo de servicio.	R-06 / T-06 (prueba diseñada; no ejecutada)
Gestion de Incidentes	Coordinar la respuesta interna y comunicar los incidentes correspondientes	Notificar y atender incidentes relacionados con sus servicios segurn el contrato	E-04 – Tráfico cloud y documentación de transferencias.	Se identificó tráfico hacia un destino externo no clasificado La asignación definitiva debe confirmarse con el contrato y el modelo de servicio.	R-06 / T-06 (prueba diseñada; no ejecutada)
Transferencia de Informacion	Autorizar las transferencias y determinar que informacion puede compartirse	Proteger las transferencias y cumplir las condiciones contractuales aplicables	E-04 y documentación de protección de datos.	Se requiere verificar la protección de la información personal La asignación definitiva debe confirmarse con el contrato y el modelo de servicio.	R-07 / T-07 (prueba diseñada; no ejecutada)
Finalizacion del servicio	Solicitar la devolucion de informacino y verificar su eliminacion	Devolver o eliminar los datos conforme a las condiciones contractuales	E-09 – Contrato y cláusulas de salida de información.	Pendiente verificar las condiciones de devolución y eliminación de datos La asignación definitiva debe confirmarse con el contrato y el modelo de servicio.	R-06 / T-06 (prueba diseñada; no ejecutada)

Evaluacion Privacidad

Hoja 3 de 5 · Contenido y observaciones del expediente

EVALUACIÓN DE PRIVACIDAD								
Proceso / sistema	**Dato tratado**	**Finalidad del tratamiento**	**Quién puede acceder**	**Ubicación / transferencia**	**Medida de protección observada**	**Evidencia / fuente**	**Resultado / limitación**	**Riesgo / prueba**
CRM comercial	Datos de clientes, contratos, ordenes y ventas	Gestion comercial de clientes, contratos, ordenes y ventas	no especificado	No especificado	No se documentan medidas especificas en el expediente inicial	Inventario tecnológico inicial, página 2. E-05 – Cambios del CRM.	No concluyente. No se dispone de información suficiente sobre los permisos y medidas de protección de los datos.	R-07 / T-07 (diseñada; no ejecutada)
SQL Server	Datos de clientes, operaciones y facturacion	Almacenamiento y consulta de informacion operatica y de facturacion	No especirficado	No especificado	No se documentan medidas especificas de cifrado o proteccion en el expediente inicial	Inventario tecnológico inicial, página 2. E-03 – Bitácora SQL Server.	No concluyente. La lectura de 31,840 registros requiere análisis adicional; no demuestra por sí sola una exposición de datos.	R-07 / T-07 (diseñada; no ejecutada)
ERP	Informacion de facturacion, cobros, inventarios y finanzas	Gestion financiera, cobros, facturacion e inventarios	No especificado	No especificado	No se documentan medidas especificas en el expediente inicial	Inventario tecnológico inicial, página 2.	No concluyente. No se dispone de información detallada sobre controles de privacidad y accesos.	R-07 / T-07 (diseñada; no ejecutada)
Aplicacion Movil	Informacion relacionada con ventas, instalaciones y clientes	Registro de ventas e instalaciones	Usuarios de la aplicacion perfiles y permisos especificos no especificados	No especificado	Se identifica una alerta sobre posibles consultas de informacion ajena al perfil autorizado	Inventario tecnológico inicial y alerta 09, página 3.	No concluyente. La alerta sobre acceso a información ajena al perfil autorizado requiere pruebas de permisos.	R-07 / T-07 (diseñada; no ejecutada)

EVALUACIÓN DE PRIVACIDAD								
Identidad / VPN	Informacion de usuarios, cuentas y sesiones de acceso	Autenticacion y administracino de accesos remotos	usuarios internos y externos, segun el inventario inicial	No especificado	Se identifica una sesion externa sin MFA en E-02	Inventario tecnológico inicial. E-01 y E-02.	No concluyente. Se requiere verificar la cobertura de MFA y la autorización de las sesiones externas.	R-03 / T-03 (diseñada; no ejecutada)
Nube / Respaldos	Informacion almacenada en servidores y resplados	Prestacion de servicios hibridos y recuperacion de informacino	RedNova y proveedor cloud, segun las responsabilidades que deben verificarse	Servicios de la nube y servidores hibridos: region no especificada	se identifican resplado programados: no se han probado recientemente las restauracinoes	Inventario tecnológico inicial. E-04 y E-08.	No concluyente. Se reporta una sesión externa sin MFA; falta verificar autorización, titularidad, cobertura MFA y registros originales.	R-06 / T-06; R-08 / T-08 (diseñada; no ejecutada)
Monitoreo / SIEM	Registros de actividad y alertas de seguridad	Monitoreo, deteccion y retencion de registros	No especificado	No especificado	Se identifica una alerta critica sin cierre documentado	Inventario tecnológico inicial. E-07.	No concluyente. El volumen de 31,840 registros leídos no demuestra por sí solo extracción o exposición de datos; faltan logs originales y atribución.	R-07 / T-07 (diseñada; no ejecutada)
Chatbot con IA / API	Datos de clientes y solicitudes procesadas por el chatbot	Atencion, clasificacion de solicitudes e integracinoes	No especificado	No especificado	Se identifica una evaluacion incompleta de provacidad, exactitud y supervision del chatbot	Inventario tecnológico inicial y alerta 10, página 3. E-10.	No concluyente. No se dispone de información detallada sobre permisos, ubicación y medidas de protección de los datos.	R-07 / T-07 (diseñada; no ejecutada)

EVALUACIÓN DE PRIVACIDAD								
							No concluyente. La alerta sobre posible acceso a información ajena al perfil requiere pruebas de permisos en entorno autorizado.	R-07 / T-07 (diseñada; no ejecutada)
							No concluyente. No se conoce la región exacta de almacenamiento ni el contenido/destino final de la transferencia aproximada de 1.6 GB.	R-07 / T-07 (diseñada; no ejecutada)
								R-07 / T-07 (diseñada; no ejecutada)
							No concluyente. El expediente refiere una evaluación incompleta de privacidad, exactitud y supervisión; no se aportaron resultados de pruebas del chatbot.	R-07 / T-07 (diseñada; no ejecutada)

Riesgos IA

FICHA DE RIESGOS DEL CHATBOT IA							
Código	**Aspecto evaluado**	**Prueba prevista**	**Resultado observado**	**Evidencia**	**Riesgo / limitación**	**Conclusión**	**Riesgo / prueba**
IA-01	Exactitud	Comprobar si las respuestas son correctas frente a información autorizada.	Prueba pendiente. No seha verificado la exactitud de las respuestas	No disponible. Prueba no ejecutada	Las respuestas incorrectas podrían generar información errónea para los clientes o colaboradores.	No concluyente	R-14 / T-14 (diseñada; no ejecutada)
IA-02	Protección de información	Verificar si revela información confidencial o datos no autorizados.	Prueba pendiente. No se ha verificado la exactitud de las respuestas. El expediente menciona un puntaje/anomalía de 0.08, pero no aporta escala, versión, umbral ni contexto para interpretarlo.	E-10 – información del chatbot/API; valor 0.08 referido sin metadatos suficientes. Prueba no ejecutada.	Sin escala ni contexto, el valor 0.08 no permite concluir que el chatbot sea seguro, exacto o que haya detectado correctamente una anomalía.	No concluyente	R-14 / T-14 (diseñada; no ejecutada)
IA-03	Permisos	Comprobar que respeta los permisos del usuario.	Prueba Pendiente. No se ha comprobado si respeta los permisos del usuario	No disponible. Prueba no ejecutada	La falta de validación de permisos podría permitir el acceso a información no autorizada.	No concluyente	R-14 / T-14 (diseñada; no ejecutada)
IA-04	Entradas engañosas / prompt injection	Evaluar si instrucciones maliciosas alteran su comportamiento o acceso.	Prueba pendiente. no se ha comprobado si respeta lo permisos del ususario	No disponible. Prueba no ejecutada	Las instrucciones maliciosas podrían alterar el comportamiento del chatbot o provocar accesos indebidos.	No concluyente	R-14 / T-14 (diseñada; no ejecutada)
IA-05	Registros y trazabilidad	Verificar si se registran las interacciones y acciones relevantes.	No se dispones de informacion suficiente para confirmar el registro de interacciones y acciones relevantes	E-10 - Informacino del chatbot y API; pendiente de revision	La falta de registros suficientes podría dificultar la trazabilidad y auditoría de las interacciones.	No concluyente	R-14 / T-14 (diseñada; no ejecutada)
IA-06	Revisión humana	Comprobar si las acciones sensibles requieren revisión o autorización humana.	No se ha verificado si las acciones sensibles requieren autorizacion humana	no disponible. Prueba no ejecutada	La ausencia de revisión humana podría permitir acciones sensibles sin autorización adecuada.	No concluyente	R-14 / T-14 (diseñada; no ejecutada)

Indicaciones

Hoja 5 de 5 · Contenido y observaciones del expediente

INDICACIONES	
Completar únicamente con información documentada del caso, contratos, configuraciones, entrevistas autorizadas o pruebas realizadas en entorno ficticio/autorizado.	
No inventar nombres de proveedores, contratos, certificaciones, ubicaciones, resultados ni incumplimientos.	
Cuando no exista información suficiente, registrar “No disponible” o “No concluyente”, según corresponda.	
La responsabilidad compartida debe ajustarse al servicio y contrato concreto; no asumir que todos los componentes corresponden al proveedor.	
Las pruebas del chatbot deben realizarse únicamente en un entorno ficticio o expresamente autorizado, sin exponer datos reales de clientes.	
Vinculación con Paso 5	Se agregaron referencias temáticas R-XX/T-XX conforme a Matriz_Riesgos.xlsx. T-06, T-03, T-07, T-08 y T-14 están DISEÑADAS, NO EJECUTADAS. La matriz SQL contiene datos sintéticos y no sustituye contrato, SOC 2, logs ni pruebas del chatbot.
Actualización documental	Revisión actualizada con los documentos del expediente disponibles al 09/11/2026. El proveedor permanece sin nombre identificado; no se recibió el contrato íntegro ni el informe SOC 2 completo. Las pruebas T-03, T-06, T-07, T-08 y T-14 permanecen diseñadas, no ejecutadas. Los resultados del laboratorio SQL son sintéticos y no sustituyen evidencia contractual, logs originales ni pruebas de privacidad/IA.